

ПРАКТИЧЕСКАЯ РАБОТА № 6.2

Тема: Разработка требований к системе защиты и ее совершенствование с использованием сканеров уязвимостей для ОС

Linux

Программное обеспечение:

1. ISO образ ОС Debian 12
<https://cloud.debian.org/images/archive/12.7.0/amd64/iso-cd/> или другая ОС Linux.

Вопросы для обсуждения:

1. Чем отличаются инструменты Lynis и Lunar между собой?
2. Какова основная цель использования инструмента Lynis?
3. Какие типы операционных систем поддерживает Lynis?
4. Назовите хотя бы одну причину, почему важно регулярно запускать инструмент Lynis?
5. Какой тип отчета генерирует Lynis после завершения анализа?
6. Почему регулярное обновление конфигурации системы и приложений помогает повысить безопасность согласно рекомендациям Lynis?
7. Каким образом Lynis обнаруживает слабые места в настройках SELinux?
8. Можно ли настроить расписание автоматического запуска проверки Lynis? Если да, каким способом?
9. Объясните значение категории результатов "Warning" в отчете Lynis.

Цель: Получение теоретических и практических навыков работы с программными средствами шифрования данных.

Основные теоретические сведения

Хотя приверженцами Linux считается, что операционная система Linux безопаснее Windows благодаря своей архитектуре и особой системе

распределения доступа между пользователями. Но из-за ошибок в системе появляются дыры, через которые злоумышленники могут обойти системы защиты. Эти ошибки составляют уязвимости, они могут встречаться в различных программах и даже в самом ядре системы подрывая ее безопасность.

Примеры уязвимостей Linux.

Dirty COW расшифровывается как Copy On Write. Ошибка возникает в файловой системе во время копирования при записи. Это локальная уязвимость, которая позволяет получить полный доступ к системе любому непривилегированному пользователю.

Для использования уязвимости нужно два файла, один доступен на запись только от имени суперпользователя, второй для нас. Если очень много раз записывать данные в наш файл и читать из файла суперпользователя, через определенное время настанет момент, когда буферы обоих файлов смешаются и пользователь сможет записать данные в файл, запись которого ему недоступна, таким образом можно выдать себе права root в системе.

Уязвимость была в ядре около 10 лет, но после обнаружения была быстро устранена, хотя остались еще миллионы устройств Android в которых ядро не обновлялось и не думает и где эту уязвимость можно эксплуатировать. Уязвимость получила код CVE-2016-5195.

GLIBC

Уязвимость получила код CVE-2015-7547. Это была одна из наиболее обсуждаемых уязвимостей среди проектов с открытым исходным кодом. В феврале 2016 выяснилось, что библиотека Glibc имеет очень серьезную уязвимость, которая позволяет злоумышленнику выполнить свой код на удаленной системе. Glibc — это реализация стандартной библиотеки Си и C++, которая используется в большинстве программ Linux, в том числе сервисов и языков программирования таких как PHP, Python, Perl.

Ошибка была допущена в коде разбора ответа DNS сервера. Таким образом, уязвимость могли использовать хакеры, к DNS которых обращались уязвимые машины, а также выполняющие MITM атаку. Но уязвимость давала полный контроль над системой HEARTBLEED. В 2014 году была обнаружена одна из самых серьезных по масштабу и последствиям уязвимость. Она была вызвана ошибкой в модуле heartdead программы OpenSSL, отсюда и название Heartbleed. Уязвимость позволяла злоумышленникам получить прямой доступ к 64 килобайтам оперативной памяти сервера, атаку можно было повторять, пока вся память не будет прочитана.

Несмотря на то, что исправление было выпущено очень быстро, пострадало очень много сайтов и приложений. Фактически уязвимыми были все сайты, использующие HTTPS для защиты трафика. Злоумышленники могли получить пароли пользователей, их личные данные и все что находилось в памяти в момент атаки. Уязвимость получила код CVE-2014-0160.

SHELLSHOCK

Эта уязвимость была обнаружена в 2014 году перед тем как просуществовала 22 года. Ей был присвоен код CVE-2014-6271 и кодовое имя Shellshock. Эта уязвимость сравнима по опасности с Heartbleed. Она вызвана ошибкой в интерпретаторе команд Bash, который используется по умолчанию в большинстве дистрибутивов Linux.

Bash позволяет объявлять переменные окружения без аутентификации пользователя, а вместе в ними можно выполнить любую команду. Особой опасности это набирает в CGI скриптах, которые поддерживаются большинством сайтов. Уязвимы не только серверы, но и персональные компьютеры пользователей, маршрутизаторы и другие устройства. По сути, злоумышленник может выполнить удаленно любую команду, это полноценное удаленное управление без аутентификации.

Потенциальные уязвимости

К потенциальным уязвимостям можно отнести также ошибки конкурентирования и настройки операционной системы, к которой должны предъявляться повышенные требования по обеспечению информационной безопасности, например:

1. отладочные файлы, образующиеся при крахе приложений (core dumps);
2. поддержка редких ФС, в которых не поддерживаются атрибуты безопасности, а также ФС, предполагающих наличие избыточных прав доступа (возможность создания файлов устройств, исполнения загрузочных модулей, установки бита смены идентификатора);
3. конфигурация системы, при которой системные и пользовательские файлы расположены в пределах общего раздела;
4. повторное использование или повторный доступ к информации, содержащейся в страницах оперативной памяти;
5. отсутствие сообщений для пользователя, совершающего вход (попытку входа) в систему о том, что в системе активизированы механизмы безопасности;
6. неверная конфигурация загрузчика, позволяющая осуществить загрузку произвольным способом в обход механизмов безопасности ОС;
7. неверная конфигурация при синхронизации времени или отсутствие синхронизации времени;
8. отсутствие установленной и запускаемой в автоматическом режиме службы аудита. Неверная конфигурация службы аудита;
9. использование службы ssh там, где оно не требуется;
10. отсутствие или неверная конфигурация средств идентификации и аутентификации;
11. отсутствие, неверная конфигурирование или отсутствие обновлений средств защиты (firewall, IDS, антивируса и т.п.);
12. нерегулярное обновление системного ПО (особенно критических обновлений безопасности).

Поиск уязвимостей Linux

Сканирование уязвимостей — процесс выявления и анализа критических недостатков безопасности в целевой среде. Иногда эту операцию называют оценкой уязвимости. Сканирование уязвимостей — одна из основных задач программы выявления и устранения этих недостатков. Существуют различные инструменты, которые могут помочь с поиском и устранением уязвимостей. В частности, они могут обнаруживать слабые места в Linux системах.

Сканер LYNIS

Lynis это известный инструмент безопасности, который пользуется популярностью среди Linux специалистов. Он также работает на системах на базе Unix и macOS. Это программное обеспечение с открытым исходным кодом, которое с 2007 года распространяется под лицензией GPL.

Lynis не требует установки. Можно извлечь его из загруженного пакета или tar архива и запустить. Чтобы получить доступ к полной документации и исходному коду, можно скачать его с Git,

Lynis был создан автором Rkhunter Майклом Боеленом. Она имеет две версии: для домашнего пользования и для предприятий. Обе версии показывают отличные результаты.

Сканер безопасности Lynis (<https://cisofy.com/lynis/>) предназначен для проверки системы по требованиям безопасности стандарта PCI-DSS. Данный стандарт широко признан в международном сообществе и соответствие его требованиям необходимо при использовании в финансовой и банковской сфере. Необходимо отметить, что сам стандарт PCI-DSS прежде всего ориентирован на информационную систему в целом. Однако для операционной системы он предполагает свыше двухсот контролей различных параметров.

```
Tests performed: 209   Plugins enabled: 0

Warnings:
-----
- Found BIND version in banner [NAME-4210]
- Found one or more vulnerable packages. [PKGS-7392]
- iptables module(s) loaded, but no rules active [FIRE-4512]
- Found one or more stratum 16 peers [TIME-3116]
- Found local source as selected time source [TIME-3124]

Suggestions:
-----
- Default umask in /etc/init.d/rc could be more strict like 027 [AUTH-9328]
- To decrease the impact of a full /home file system, place /home on a separated partition
- To decrease the impact of a full /tmp file system, place /tmp on a separated partition
- Disable drivers like USB storage when not used, to prevent unauthorized storage or data
- The version in BIND can be masked by defining 'version none' in the configuration file
- Purge old/removed packages (66 found) with aptitude purge or dpkg --purge command. This
- Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or
- Access to CUPS configuration could be more strict. [PRNT-2307]
- Disable iptables kernel module if not used or make sure rules are being used [FIRE-4512]
- Harden PHP by disabling risky functions [PHP-2320]
- Check what deleted files are still in use and why. [LOGG-2190]
- Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
- Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
- Enable sysstat to collect accounting (disabled) [ACCT-9626]
- Check ntpq peers output [TIME-3116]
- Check ntpq peers output [TIME-3124]
- Check ntpq peers output for time source candidates [TIME-3128]
- One or more sysctl values differ from the scan profile and could be tweaked [KRNL-6000]
- Harden the system by removing unneeded compilers. This can decrease the chance of
- Harden compilers and restrict access to world [HRDN-7222]

Follow-up:
-----
- Fix findings, see security controls overview and documentation
- Upload data to Lynis Enterprise for further analysis
- Create a report and implementation plan

Enterprise support and plugins available via CISOfy - http://cisofy.com

Hardening index : [75]   [#####]

Files:
- Test and debug information      : /var/log/lynis.log
- Report data                    : /var/log/lynis-report.dat
```

Рисунок 1. Параметры Lynis

Lynis можно загрузить и установить.

Lynis входит в пакет Kali Linux, но также может быть клонирован с GitHub или скачан с официального сайта (<https://cisofy.com/documentation/lynis/get-started/#installation>).

Для установки актуальной версии сканера безопасности Lynis (бесплатная версия с открытым исходным кодом) рекомендуется выполнить подключение актуального репозитория разработчика сканера.

Для запуска приложения из командной строки введите в терминале команду `lynis`. Она отобразит установленную версию Lynis (в данном случае 2.6.2) и инициализирует программу. Вы также увидите список всех параметров команды:

```

root@kali:~# lynis

[ Lynis 2.6.2 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2018, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----

Usage: lynis command [options]

Command:

audit
  audit system          : Perform local security scan
  audit system remote <host> : Remote security scan
  audit dockerfile <file> : Analyze Dockerfile

show
  show          : Show all commands
  show version  : Show Lynis version
  show help     : Show help

update
  update info   : Show update details

```

Рисунок 2. Список всех параметров команды.

Если нужно уточнить команду, введите lynis show commands:

```

root@kali:~# lynis show commands

Commands:
lynis audit
lynis configure
lynis show
lynis update
lynis upload-only

root@kali:~#

```

Рисунок 3. Команда lynis show commands

Lynis — полностью механизированный инструмент проверки безопасности, у которого есть минимальный набор команд.

Некоторые тесты могут быть пропущены если Вы не используете режим суперпользователя.

Для запуска сканера безопасности Lynis и получения отчета, выполнить:

lynis audit system

Время, которое займет проверка, зависит от характеристик проверяемой машины Linux. Обычно проверка длится от 15 до 30 минут. Отчёт делится на различные разделы, и каждый раздел начинается с [+]:

- [+] Boot and services
- [+] Kernel
- [+] Memory and Processes
- [+] Users, Groups and Authentication
- [+] Shells
- [+] File systems

- [+] USB Devices
- [+] Storage
- [+] NFS
- [+] Name services
- [+] Ports and packages
- [+] Networking

- [+] Printers and Spools
- [+] Software: e-mail and messaging
- [+] Software: firewalls
- [+] Software: webserver
- [+] SSH Support
- [+] SNMP Support

- [+] Databases

- [+] LDAP Services
- [+] PHP
- [+] Squid Support
- [+] Logging and files
- [+] Insecure services

- [+] Banners and identification
- [+] Scheduled tasks
- [+] Accounting
- [+] Time and Synchronization
- [+] Cryptography
- [+] Virtualization
- [+] Containers
- [+] Security frameworks
- [+] Software: file integrity

- [+] Software: System tooling
- [+] Software: Malware
- [+] File Permissions
- [+] Home directories

- [+] Kernel Hardening
- [+] Hardening
- [+] Custom tests

Начало выводимых результатов проверки показано на рисунке:

```
root@kali:~# lynis audit system

[ Lynis 2.6.2 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2018, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----
- Detecting OS... [ DONE ]
- Checking profiles... [ DONE ]

-----
Program version:      2.6.2
Operating system:     Linux
Operating system name: Debian
Operating system version: kali-rolling
Kernel version:       4.15.0
Hardware platform:    x86_64
Hostname:             kali
-----
```

Рисунок 4. Начало процесса вывода результатов сканирования

Как уже указывалось выше, результаты проверки в разных разделах включают в себя сведения о:

- версии Debian;
- загрузке и службах;
- ядре;
- памяти и процессоре;
- пользователях, группах и проверке подлинности;
- оболочке;
- файловой системе;
- USB-устройствах;
- сети и брандмауэрах;
- портах и принтерах;
- надежности ядра.

А также предупреждения и предложения. Для большей наглядности Lynis использует условные обозначения в виде цветов:

- **зелёный:** всё хорошо
- **жёлтый:** не нашёл всё необходимое, или возникла спорная ситуация
- **красный:** это проблема, стоит с ней разобраться

```
[+] Networking
-----
- Checking IPv6 configuration [ ENABLED ]
  Configuration method [ AUTO ]
  IPv6 only [ NO ]
- Checking configured nameservers
- Testing nameservers
  Nameserver: 10.2.0.24 [ OK ]
- Minimal of 2 responsive nameservers [ WARNING ]
- Checking default gateway [ DONE ]
- Getting listening ports (TCP/UDP) [ DONE ]
  * Found 1 ports
- Checking promiscuous interfaces [ OK ]
- Checking waiting connections [ OK ]
- Checking status DHCP client [ RUNNING ]
- Checking for ARP monitoring software [ NOT FOUND ]

[+] Printers and Spools
-----
- Checking cups daemon [ NOT FOUND ]
- Checking lp daemon [ NOT RUNNING ]

[+] Software: e-mail and messaging
-----

[+] Software: firewalls
-----
- Checking iptables kernel module [ FOUND ]
- Checking iptables policies of chains [ FOUND ]
- Checking for empty ruleset [ WARNING ]
- Checking for unused rules [ OK ]
- Checking host based firewall [ ACTIVE ]

[+] Software: webserver
-----
- Checking Apache (binary /usr/sbin/apache2) [ FOUND ]
  Info: Configuration file found (/etc/apache2/apache2.conf)
  Info: No virtual hosts found
* Loadable modules [ FOUND (116) ]
  - Found 116 loadable modules
    mod_evasive: anti-DoS/brute force [ NOT FOUND ]
    mod_reqtimeout/mod_qos [ FOUND ]
```

Рисунок 5. Процесс сканирования

```
-[ Lynis 2.6.2 Results ]-

Warnings (4):
-----
! No password set for single mode [AUTH-9308]
  https://cisofy.com/controls/AUTH-9308/

! Can't find any security repository in /etc/apt/sources.list or sources.list.
d directory [PKGS-7388]
  https://cisofy.com/controls/PKGS-7388/

! Couldn't find 2 responsive nameservers [NETW-2705]
  https://cisofy.com/controls/NETW-2705/

! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/controls/FIRE-4512/

Suggestions (40):
-----
* This release is more than 4 months old. Consider upgrading [LYNIS]
  https://cisofy.com/controls/LYNIS/

* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [CUST-0280]
  https://your-domain.example.org/controls/CUST-0280/

* Install libpam-usb to enable multi-factor authentication for PAM sessions [C
UST-0285]
```

Рисунок 6. Предупреждение о имеющихся уязвимостях

Дистрибутив может не устанавливать параметры по умолчанию по разным причинам, поэтому необходимо изучить каждый из них и посмотреть, нужно ли вам менять его значение в зависимости от ваших требований к безопасности.

Lynis вносит предложения по исправлению, основанные на результатах аудита. Каждое предложение начинается с описания, а рядом в скобках указывается тест (TEST-ID), который его сгенерировал. В следующей строке предлагается решение проблемы, если оно существует.

Кроме того, Lynis даёт возможность найти дополнительную информацию о каждом предложении по исправлению с помощью команды `show details`, за которой следует номер теста TEST-ID.

В конце приводится общая сводка:

```
Lynis security scan details:

Hardening index : 56 [#####          ]
Tests performed : 223
Plugins enabled : 1

Components:
- Firewall                [V]
- Malware scanner         [V]

Lynis Modules:
- Compliance Status       [?]
- Security Audit          [V]
- Vulnerability Scan      [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

Рисунок 7. Результат сканирования

Обычно итоговый индекс считается приемлемым если он больше 80.

Сканер LUNAR

LUNAR – сокращение от Lockdown UNIX Auditing and Reporting. Этот сценарий генерирует отчет аудита безопасности хоста UNIX. Он основан на CIS и других фреймворках.

Поддерживаемые ОС и дистрибутивы Linux.

RHEL 5,6,7;

Centos 5,6,7;

Scientific Linux;

SLES 10,11,12;

Debian;

Ubuntu;

Amazon Linux;

Solaris (6,7,8,9,10 и 11);

Mac OS X.

Утилита также поддерживает облачную платформу Amazon и контейнеры Docker.

LUNAR обычно используется для оценки безопасности, самооценки или повышения безопасности системы.

Установка и запуск

LUNAR это сценарий командной строки sh, поэтому особых усилий по установке он не требует. Выгружаем архив (<https://github.com/lateralblast/lunar>) с Github, распаковываем в соответствующую директорию и запускаем из командной строки.

\$./lunar.sh -a

Рекомендуется запускать в режиме аудита (параметр -a).

Будьте внимательны и осторожны при запуске в режиме исправлений!

Список параметров:

-a – запуск в режиме аудита (в систему не вносятся изменения); -v – подробный режим [используется с -a и -A];

-d – просмотр предлагаемых изменений системы до их внесения в конфигу;

-s – запуск в выборочном режиме;

-l – запуск в режиме блокировки (внесение изменений);

-S – список всех функций UNIX, доступных для выборочного режима;

-W – список всех функций AWS, доступных для выборочного режима;

-D – список всех функций Docker, доступных для выборочного режима;

-Z – показать изменения, ранее внесенные в систему;

-b – список файлов резервных копий;

-n – выводить доступные сегменты кода;

-u – восстановление из резервной копии.

Дополнительный материал по hardening – guide от ОС Debian можно ознакомиться по следующим ссылками:

<https://www.debian.org/doc/manuals/securing-debian-manual/>

Задание к практической работе

Подготовка среды

Для проведения практического занятия:

1. Установить (если его нет в Вашей ОС) гипервизор управления виртуальными машинами (Virtualbox, Vmware)
2. Установить виртуальную машину с одной из распространенных версий Linux систем (Ubuntu 18.04 - 20.10, Linux Debian, Kali Linux и пр.) с поддержкой выхода в сеть.
3. Установить в виртуальную машину сканеры уязвимостей LYNIS и LUNAR (как описано выше)

Этапы выполнения работы

4. Сохранить первоначальный образ виртуальной машины (это образ понадобится на шаге 11 для восстановления системы с целью сравнения сканеров LYNIS и LUNAR)
5. Провести сканирование ОС виртуальной машины сканером LYNIS.
6. Изучить список обнаруженных недостатков и рекомендаций. Первоначальный отчет сохранить (с целью сравнения сканеров LYNIS и LUNAR на шаге 12). Запомнить исходный индекс безопасности.
7. Оценить возможность и целесообразность устранения недостатков и выполнения рекомендаций.
8. В произвольном порядке изучать и устранять отмеченные недостатки и проводить повторное сканирование с целью оценки повышения индекса безопасности (желательно добиться рекомендованного выше значения)
9. Сохранить для отчета: общую характеристику системы, первоначальный индекс безопасности, первоначальный список замечаний, описание всех выполненных действий по устранению части замечаний, итоговый индекс безопасности.

10. Восстановить ОС из исходного образа, созданного на шаге 4.

11. Провести сканирование ОС виртуальной машины сканером LUNAR (без внесения исправлений!)

12. Сопоставить выявленные уязвимости LUNAR и список уязвимостей от первоначального сканирования LYNIS (шаг 5).

13. Провести сканирование ОС виртуальной машины сканером LUNAR (с внесением исправлений!) - оценить изменение индекса защищенности (через запуск LYNIS, если после автоматических исправлений система сохранит работоспособность). Полученные значения сохранить для отчета.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания и ответы на вопросы практической работы.

Содержание отчета о проделанной работе.

Отчет готовится в произвольной форме, но быть читаемым и должен содержать указанную ниже информацию.

- 1) Данные об авторе отчета и проводимой работе
- 2) Раздел об использованном оборудовании, версиях использованного ПО
- 3) Раздел с результатами первоначального и заключительного сканирования LYNIS в части индекса защищенности, выявленных недостатках, исправленных недостатках, комментарии по неисправленным недостаткам (неактуальны, нужное свойство, непонятны)
- 4) Раздел с результатами сравнения сканеров LINIS и LUNAR по выявлению уязвимостей
- 5) Раздел с результатами использования автоматического исправления настроек сканером LUNAR с оценкой их эффективности по индексу безопасности, построенному при помощи LYNIS.